

Northbridge - Third-Party Risk Assessment

Vendor	DataFlow AI	Domain	Weight	Score	Weighted	Highest Risk
Risk Tier	Critical	Governance		10%	4	8% Medium
Assessment Decision	Conditional Approval	IAM		20%	3	12% High
Weighted Score	71%	Data Security		20%	4	16% Medium
High Findings	2	Infrastructure Security		15%	4	12% Medium
Open Findings	3	Application Security		15%	3	9% Medium
Assessment Date	2026-08-26	Incident Response and BCP		10%	3	6% High
		Compliance and Assurance		10%	4	8% Medium

Top Findings	Domain	Severity	Risk	Recommendation	Owner	Due Date	Status
F-001	IAM	High	Unauthorized administrative access could affect customer data and service integrity.	Require privileged MFA evidence before production integration.	DataFlow AI Security Lead	2026-09-30	Open
F-002	Legal / Incident Response	High	Northbridge may not receive timely notice needed for customer and legal obligations.	Add contract language for timely notification and required incident details.	Northbridge Legal	2026-09-20	Open
F-003	Application Security	Medium	Application weaknesses may remain undiscovered longer than Northbridge's target risk tolerance.	Require annual penetration test or documented compensating control.	DataFlow AI Security Lead	2026-10-31	In Progress
F-004	Incident Response	Medium	Response roles and communications may be untested during a customer-impacting incident.	Request tabletop evidence or scheduled exercise date.	DataFlow AI Compliance Manager	2026-11-15	Open
F-005	Security Awareness	Low	Contractors may not receive the same security awareness expectations as employees.	Expand training evidence to contractor population.	DataFlow AI HR / Compliance	2026-12-15	Planned

Vendor Profile and Inherent Risk

Vendor	DataFlow AI	Service	AI-assisted customer-support analytics
Data Types	Confidential customer business data; support metadata; limited user identifiers	Hosting	Cloud SaaS
Integration	API integration with Northbridge application and Salesforce	Business Owner	Customer Operations
Inherent Risk Tier	Critical	Assessment Type	Pre-contract security review
Risk Rationale	Processes customer data and integrates with production support workflow	Decision	Conditional Approval
Review Frequency	Annual critical vendor review	Next Review	2027-08-26
Primary Framework	NIST SP 800-161 Rev. 1 Update 1	Supporting Frameworks	NIST CSF 2.0, CIS v8.1, ISO, SOC 2
Data Location	United States cloud region assumed	Subprocessors	Disclosed by vendor
Contract Status	Security exhibit under legal review	Risk Acceptance Required	No, if high findings close before production
Assessment Owner	Northbridge GRC Lead	Assessment Date	2026-08-26

Domain	Question	Response	Evidence Reviewed	Score	Framework Reference
Governance	Does the vendor maintain an information security program with assigned ownership?	Yes	Security policy and org chart		4 ISO 27001 Clause 5; NIST CSF GV.RR
Governance	Are security policies reviewed at least annually?	Partial	Policy set provided, review cadence unclear		3 ISO 27001 Clause 5; SOC 2 CC1
IAM	Is MFA required for workforce access?	Yes	MFA policy		4 CIS 6; NIST 800-53 IA-2
IAM	Is MFA required and evidenced for privileged administrators?	Partial	Policy provided, admin evidence missing		2 CIS 6; NIST 800-53 IA-2
IAM	Are access reviews performed for privileged users?	Partial	Access review summary, no sample evidence		3 NIST 800-53 AC-2; SOC 2 CC6
Data Security	Is customer data encrypted at rest and in transit?	Yes	Architecture and encryption statement		5 ISO 27002; ISO 27017
Data Security	Are retention and deletion requirements documented?	Yes	Retention policy		4 ISO 27002; SOC 2 Confidentiality
Data Security	Are subprocessors disclosed?	Yes	Subprocessor list		4 NIST CSF GV.SC
Infrastructure	Are vulnerability scans performed regularly?	Yes	Vulnerability procedure		4 CIS 7; NIST 800-53 RA-5
Infrastructure	Are critical vulnerabilities remediated under SLA?	Partial	SLA exists, aging evidence limited		3 CIS 7; NIST 800-53 SI-2
Infrastructure	Are cloud configuration controls monitored?	Partial	Cloud control summary		3 ISO 27017; CIS 4
Application Security	Does the vendor maintain secure SDLC practices?	Yes	SDLC policy		4 CIS 16; NIST 800-53 SA-10
Application Security	Is independent penetration testing performed annually?	No	Last test summary shows two-year cadence		2 SOC 2 CC7; CIS 18
Application Security	Are high and critical findings tracked to closure?	Partial	Summary remediation statement		3 NIST 800-53 CA-5
Incident Response	Does the vendor maintain an incident-response plan?	Yes	IR plan		4 NIST SP 800-61 Rev. 3
Incident Response	Has the incident-response plan been tested recently?	No	Unable to test — evidence not provided. No tabletop evidence (F-004).		2 NIST SP 800-61 Rev. 3; CIS 17
Incident Response	Are breach notification obligations contractually defined?	Partial	Contract language lacks timeline		2 SOC 2 CC7; Legal requirement
Business Continuity	Does the vendor maintain BCP/DR procedures?	Yes	BCP statement		4 NIST 800-53 CP family
Business Continuity	Are recovery objectives documented and tested?	Partial	RTO/RPO provided, test evidence limited		3 NIST 800-53 CP-4, CP-10
Compliance	Is a SOC 2 or equivalent assurance report available?	Yes	SOC 2 executive summary		4 AICPA TSC
Compliance	Are audit exceptions tracked and remediated?	Partial	Exception summary provided		3 SOC 2 CC4; CC5
Privacy	Does the vendor document data processing and privacy obligations?	Yes	DPA and privacy summary		4 ISO 27001; SOC 2 Privacy
Contract	Are security requirements included in the contract?	Partial	Security exhibit provided		3 NIST CSF GV.SC
Contract	Are right-to-audit or assurance-review rights included?	Partial	Annual assurance review allowed		3 NIST SP 800-161
Monitoring	Will Northbridge receive security status or risk updates?	Partial	Customer portal available, no formal cadence		3 NIST CSF GV.SC

Domain	Weight	Score	Weighted Score	Assessment Notes	Highest Risk
Governance		10%	4	8% Policies and security ownership exist; risk-review cadence needs improvement.	Medium
IAM		20%	3	12% MFA exists, but privileged MFA evidence is incomplete.	High
Data Security		20%	4	16% Encryption, retention, and deletion practices are documented.	Medium
Infrastructure Security		15%	4	12% Cloud controls exist; configuration evidence is limited.	Medium
Application Security		15%	3	9% Secure SDLC exists; penetration testing cadence is below target.	Medium
Incident Response and BCP		10%	3	6% Plans exist, but tabletop and notification evidence are incomplete.	High
Compliance and Assurance		10%	4	8% SOC 2 evidence is available; exceptions require follow-up.	Medium
Overall Weighted Score			71%		
Decision Threshold	>=80% Approve; Decision 65%-79% Conditional; <65% Reject		Conditional Approval		

Finding ID	Domain	Finding	Severity	Evidence Reviewed	Risk	Recommendation	Owner	Due Date	Status	Validation Evidence
F-001	IAM	Privileged MFA evidence incomplete	High	Vendor provided MFA policy but not an administrator enrollment export or exception list.	Unauthorized administrative access could affect customer data and service integrity.	Require privileged MFA evidence before production integration.	DataFlow AI Security Lead	2026-09-30	Open	MFA configuration export, admin enrollment evidence, approved exception log
F-002	Legal / Incident Response	Breach notification terms not contractually specific	High	Security exhibit references incident notification but does not define timeline or minimum content.	Northbridge may not receive timely notice needed for customer and legal obligations.	Add contract language for timely notification and required incident details.	Northbridge Legal	2026-09-20	Open	Executed contract addendum or redlined clause
F-003	Application Security	Penetration testing occurs every two years	Medium	Vendor provided last external test summary from 2025 and stated testing is every two years.	Application weaknesses may remain undiscovered longer than Northbridge's target risk tolerance.	Require annual penetration test or documented compensating control.	DataFlow AI Security Lead	2026-10-31	In Progress	Updated testing schedule or compensating-control approval
F-004	Incident Response	Tabletop exercise evidence not provided	Medium	Unable to test — evidence not provided. Vendor provided incident-response plan but no recent exercise report.	Response roles and communications may be untested during a customer-impacting incident.	Request tabletop evidence or scheduled exercise date.	DataFlow AI Compliance Manager	2026-11-15	Open	Exercise report, participant list, lessons learned
F-005	Security Awareness	Contractor training evidence incomplete	Low	Training report covered employees but did not show contractor completion.	Contractors may not receive the same security awareness expectations as employees.	Expand training evidence to contractor population.	DataFlow AI HR / Compliance	2026-12-15	Planned	Training completion report including contractors

Finding ID	Required Action	Owner	Due Date	Status	Days Until Due	Escalation	Closure Criteria
F-001	Require privileged MFA evidence before production integration.	DataFlow AI Security Lead	2026-09-30	Open		35 Escalate to CISO if overdue	MFA configuration export, admin enrollment evidence, approved exception log
F-002	Add contract language for timely notification and required incident details.	Northbridge Legal	2026-09-20	Open		25 Escalate to CISO if overdue	Executed contract addendum or redlined clause
F-003	Require annual penetration test or documented compensating control.	DataFlow AI Security Lead	2026-10-31	In Progress		66 Track in vendor review	Updated testing schedule or compensating-control approval
F-004	Request tabletop evidence or scheduled exercise date.	DataFlow AI Compliance Manager	2026-11-15	Open		81 Track in vendor review	Exercise report, participant list, lessons learned
F-005	Expand training evidence to contractor population.	DataFlow AI HR / Compliance	2026-12-15	Planned		111 Track in vendor review	Training completion report including contractors

Vendor Decision Memo

Vendor	DataFlow AI	Decision	Conditional Approval
Business Need	AI-assisted support analytics for customer operations	Risk Tier	Critical
Rationale	Vendor has a reasonable security foundation, but high findings must close before full production use.	Score	71%
Required Conditions	Privileged MFA evidence; breach-notification language; annual penetration test commitment; IR tabletop evidence.	Approval Owner	CISO / Legal / Customer Operations
Production Use	Limited implementation only until high findings are closed.	Risk Acceptance	Not recommended for unresolved high findings
Executive Message	This is a managed business-risk decision, not a simple pass/fail checklist.	Next Review	2027-08-26
Interview Talking Point	Conditional approval supports the business while preserving risk accountability.	Assessment Date	2026-08-26
Portfolio Skill	Vendor classification, evidence review, findings, remediation tracking, and decision documentation.	Primary Standard	NIST SP 800-161 Rev. 1 Update 1

Reference	URL	Use in Workbook
NIST SP 800-161 Rev. 1 Update 1	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Supply-chain cybersecurity risk methodology
NIST CSF 2.0	https://www.nist.gov/cyberframework	Governance and supply-chain outcome alignment
NIST IR 8286 Rev. 1	https://csrc.nist.gov/pubs/ir/8286/r1/final	Enterprise-risk reporting context
NIST SP 800-53 Rev. 5 Release 5.2.0	https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls	Control references
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final	Evidence and assessment logic
NIST SP 800-61 Rev. 3	https://csrc.nist.gov/pubs/sp/800/61/r3/final	Incident response and notification review
CIS Controls v8.1	https://www.cisecurity.org/controls/v8-1	Practical safeguard mapping
ISO/IEC 27001:2022/Amd 1:2024	https://www.iso.org/standard/88435.html	ISMS alignment
ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	Security control guidance
ISO/IEC 27017:2026	https://www.iso.org/standard/43757.html	Cloud-service control considerations
AICPA TSC revised points of focus 2022	https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022	SOC 2 evidence review
Scenario dates and rating definitions	Fictional assessment assumptions; see shared company profile	../00-company-profile/Northbridge-Company-and-GRC-Scope.md